

Course Project: Final Paper

Scattered Spider and The MGM Social Engineering Attack

CSEC 645: Social Engineering

Roberto Reade

May 4, 2026

Introduction and Background

The cyberattack on MGM Resorts that was initiated by a 10-minute phone call using LinkedIn data, serves as an illustration of a shift in the current threat landscape (Culafi, 2023; Sudbeck, 2024). This incident, which provided attackers with administrative access to one of the largest casino-hotel networks at virtually zero cost, highlights an important principle. Adversaries no longer only target technical vulnerabilities but increasingly exploit humans through social engineering tactics (Baccio, 2024; CrowdStrike, 2026).

The MGM breach, its \$100 million financial impact, a 10-day operational outage, and the compromise of millions of customer records, stands as a defining social engineering case study (Brown & Brown, 2024; Schrader, 2025). It exposes the weaknesses in enterprise identity verification processes at the human level and shows that technical investments alone can't fully compensate for procedural failures (Sudbeck, 2024).

This paper aims to provide a comprehensive analysis of this evolving threat. Specifically, it will provide the profile of Scattered Spider, document their TTPs, and provide a reconstruction of the MGM attack. It will also evaluate MGM's defensive posture and incident response, providing recommendations based on cybersecurity best practices.

In the broader context, social engineering has emerged as the dominant initial access vector in modern attacks. This shows a clear shift from purely technical exploitation to human manipulation as the path of least resistance for threat actors. Scattered Spider, through their skilled use of social engineering to compromise high-profile targets such as MGM, serves as a compelling case study proving this broader and critical trend.

Literature Review

Social Engineering: Foundation

Social engineering attacks often leverage established psychological principles to manipulate individuals. Cialdini's principles of influence, including reciprocity, authority, social proof, and urgency/scarcity, are frequently exploited. The application of these principles in social engineering has been a subject of inquiry (Ferreira et al., 2015). In addition, Hadnagy's social engineering lifecycle, which includes reconnaissance, pretexting, elicitation, and post-engagement, provides a framework for understanding the approach of threat actors like Scattered Spider. Kevin Mitnick's concept of the "human firewall" underscores the argument that human elements often represent the weakest link in security (Salahdine & Kaabouch, 2019).

Vishing Attack Vector

Vishing represents a distinct attack vector from traditional phishing due to its reliance on real-time interaction. A significant aspect of vishing involves help desk social engineering, where attackers exploit the "authority bias" prevalent in IT support contexts (Jones et al., 2020). Agents are often conditioned to resolve issues rather than interrogate requests. Additionally, guidance from organizations like SANS and NIST provides insights into social engineering and identity verification best practices (Triantafyllopoulos et al., 2025).

MFA Weaknesses and Bypass Techniques

MFA still has vulnerabilities. Research on MFA fatigue attacks highlights how push notification bombarding can exploit user frustration, leading to approvals (CISA, 2022). CISA advisories and academic work have documented these tactics. SIM-swapping has acquired significant academic and regulatory attention following high-profile cases. In addition, the abuse of SSRP mechanisms is an underexamined attack surface, effectively serving as a "back door" through technical controls (Cyber Safety Review Board, 2022).

Cloud Identity and SSO Risk

The adoption of cloud-first enterprise identity architectures introduces risks, as the "single pane of glass" can become a single point of failure. The MITRE ATT&CK framework maps threat groups like Scattered Spider under Group G1015, detailing relevant techniques such as T1566 (Phishing), T1078 (Valid Accounts), T1621 (Multi-Factor Authentication Request Generation), and T1556 (Bypass Multi-Factor Authentication) (Rose et al., 2020). In response to identity-centric attacks, the Zero Trust Architecture, as outlined by NIST SP 800-207, has emerged as an academic and industry approach (DOJ & CISA, 2023).

Ransomware-as-a-Service Ecosystem

The RaaS model has evolved into a sophisticated ecosystem, characterized by a clear division of labor between "access brokers," such as Scattered Spider, and ransomware operators like ALPHV/BlackCat. This is driven by the economics of the ransomware ecosystem, enabling efficiency and scale in attacks (Phipps & Nurse, 2025). The debate surrounding ransom payments is a critical aspect, with cases like MGM's refusal versus Caesars' payment serving as important case studies (Cartwright et al, 2019).

Case Description

Scattered Spider Profile

Scattered Spider is a financially motivated cybercriminal group that emerged in early 2022 (Baccio, 2024; Bitsight TRACE, 2025). Unlike traditional threat actors, Scattered Spider operates as an informal network of individuals, small sub-groups, and recruited specialists who share tactics, targets, and tools across encrypted platforms including Telegram and Discord (Henriques, 2025; Lazerowitz, 2025).

The group is tracked under a range of aliases by different cybersecurity vendors and agencies. Some of these names include UNC3944, Octo Tempest, Muddled Libra, LUCR-3, and Storm-8057(CrowdStrike, 2026; MITRE, n.d.).

Scattered Spider operates from the United States, United Kingdom, and Western Europe. Members are young, English-speaking individuals. Their native English fluency gives them an advantage when impersonating employees at English-speaking organizations, especially when interacting with IT help desks (Culley, 2025; Huntress, n.d.).

Scattered Spider is best understood as a community rather than a corporation. There is no hierarchy. Instead, the group operates by recruiting individuals with specialist skills on an as-needed basis.

All known activities are financially motivated. The group's criminal objectives include Data theft and extortion, Ransomware deployment, SIM-swapping for cryptocurrency theft, and Credential resale (Baccio, 2024; Bitsight TRACE, 2025).

Evolution and Target History

The group's target strategy has evolved since its emergence. Three distinct phases of their operations can be identified.

Phase one was in early 2022 and focused on telecommunications and SIM-swapping (Australian Cyber Security Centre, 2025; Culley, 2025). Early campaigns focused primarily on telecommunications companies and business process outsourcing firms. The objective was to facilitate SIM-swapping enabling interception of SMS-based MFA codes.

Phase two in middle to late 2022 was the Oktapus Mass Phishing Campaign. Scattered Spider dramatically expanded their scale through the Oktapus campaign. This was a SMS phishing operation targeting over 130 organizations simultaneously (Baccio, 2024; CrowdStrike,

2026). The campaign collected employee credentials and MFA tokens. This phase demonstrated the group's capacity for coordinated attacks.

Phase three, from 2023 to now, focusses on enterprise ransomware and cloud identity exploitation (Foulger, 2025; Obsidian, 2025). Scattered Spider pivoted toward high-value enterprise targets in hospitality, gaming, retail, and financial sectors. Their tactics evolved to focus on cloud identity providers using social engineering to gain administrator credentials, then deploying ransomware or conducting mass data exfiltration.

Post-2024, research indicates continued evolution toward sophisticated voice-based phishing operations and the exploitation of SaaS environments including Salesforce, HubSpot, and VMware ESXi infrastructure (Foulger, 2025; Obsidian, 2025).

Members and Law Enforcement

Law enforcement actions starting in 2024 revealed several identified members. However, the group's decentralized structure means arrests have not significantly disrupted operations (Bitsight TRACE, 2025; Scattered Spider, 2023). Tyler Buchanan, who was their alleged leader, was arrested in Spain in June 2024 while attempting to flee to Italy. Noah Michael Urban was arrested in Florida in January 2024 and charged with theft of \$800,000 in cryptocurrency. Ahmed Elbadawy and Remington Ogletree were indicted in November 2024 as part of a DOJ action for a phishing campaign. There was an unnamed 17-year-old arrested July 2024 in connection with the MGM Resorts attack and an unnamed juvenile who surrendered to authorities in Clark County, Nevada in connection with the 2023 casino hacks (Brown & Brown, 2024; Scattered Spider, 2023).

TTP's

Scattered Spider's defining characteristic is their mastery of social engineering. Their attack lifecycle follows a pattern across all documented campaigns (Avanzato, 2025; CrowdStrike, 2026).

Pre Attack: Reconnaissance

Before any contact is made, the group conducts detailed reconnaissance using publicly available sources. LinkedIn is the primary platform, enabling attackers to identify employees by name, job title, and department (Schrader, 2025; Sudbeck, 2024). This allows them to build a convincing profile of a legitimate individual to impersonate.

Beyond LinkedIn, reconnaissance includes probing SSPR workflows to identify which recovery channels are associated with target accounts, third-party IT support vendors or managed service providers used, mapping the target's cloud identity infrastructure, and researching the target organization's business relationships to identify trusted supply chain partners who may have privileged access (Schrader, 2025; Sudbeck, 2024).

Initial Access Methods

Vishing

With reconnaissance complete, attackers place a phone call to the target organization's IT help desk or to a third-party support provider. With accurate personal details about a real employee, they impersonate that employee and request a credential or MFA reset (Culafi, 2023; Sudbeck, 2024).

Social engineering is effective because help desk agents are trained to be helpful. The attacker's use of accurate personal details provides credibility. The request is routine since help desks process dozens of these requests, and the call is brief.

This highlights an ethical issue where employees are expected to prioritize helpfulness yet are held accountable when that behavior is exploited. It is questionable to rely on human judgment alone in high-risk authentication scenarios without stronger safeguards.

MFA Fatigue

When the group has access to a valid password but is blocked by MFA, they employ push notification fatigue by sending repeated authentication requests to the victim's device (CrowdStrike, 2026; MITRE, n.d.). The objective is to cause the user to approve a request out of confusion, frustration, or to stop the interruptions.

SIM Swapping

For SMS-based MFA, this is accomplished by social engineering mobile carrier staff to transfer a victim's phone number to an attacker-controlled SIM card. This allows them to receive SMS authentication codes and bypass phone-based MFA entirely (Australian Cyber Security Centre, 2025; Culley, 2025).

SSPR Abuse

SSPR is designed to allow users to recover their own accounts. However, it becomes an attack vector when an attacker can manipulate the recovery. Scattered Spider has been observed replacing victim account recovery phone numbers with attacker-controlled Google Voice VoIP numbers, then triggering SSPR flows to reset passwords and gain access (Foulger, 2025; Obsidian, 2025).

Post Access: Lateral Movement and Escalation

Once initial access is achieved, the group moves with speed. In some cases, lateral movement from initial cloud compromise to full network access has occurred in roughly four minutes.

SSO

Modern enterprises use SSO platforms to allow employees to access dozens of applications with a single set of credentials. Once an attacker controls a valid identity within this system, SSO becomes a highway for lateral movement (MITRE, n.d.; Obsidian, 2025). Attackers can pivot from cloud applications into corporate VPNs, internal systems, and on-premises infrastructure within minutes.

Privilege Escalation

The group seeks to escalate from standard user accounts to administrative privileges. Documented techniques include assigning administrative roles to compromised service accounts, resetting credentials for high-privilege service accounts, and creating new administrative accounts disguised as service accounts to maintain persistent privileged access (CrowdStrike, 2026; MITRE, n.d.).

Persistence

To maintain access, the group employs several persistence techniques. First, registering Temporary Access Passes on victim accounts. Second, adding attacker-controlled authentication devices to victim accounts. This ensures continued access even if passwords are reset. Third, deleting Conditional Access Policies that block access from suspicious IP addresses or enforce MFA for administrative actions. Lastly, disabling legitimate user accounts and removing administrative roles to delay incident response (Foulger, 2025; Obsidian, 2025).

Defense Evasion

The group actively works to delay detection and response. Scattered Spider disguise malicious accounts as legitimate service accounts, using naming conventions that match the target's account structure. They route traffic through commercial VPNs and satellite connections to hide their IP addresses. They also monitor victim organizations communications to track incident response activity and adjust their behavior. Lastly, Scattered Spider moves through the

corporate network from internal IP addresses, which are often whitelisted in anomaly detection systems (Foulger, 2025; Henriques, 2025).

Ransomware Deployment

For their most destructive campaigns, Scattered Spider partners with RaaS operators. Their primary partner has been ALPHV also known as BlackCat, which is a Russia-based RaaS operation (Baccio, 2024; Schrader, 2025). The group specifically targets VMware ESXi hypervisors. Encrypting these servers disables the thousands of virtual machines simultaneously. This causes operational disruption across guest-facing, administrative, and backend systems.

MGM Resorts Attack

Why MGM Was Targeted

MGM Resorts is one of the largest hospitality and entertainment corporations. As of 2023, the company operated over 30 hotel and casino destinations. The company generated billions in revenue and employed tens of thousands of staff.

From a cybersecurity perspective, MGM was an attractive target. Modern casino-resort operations are highly digital and closely connected, with gaming systems, hospitality services, customer databases, mobile apps, and corporate systems all linked through central networks. This includes everything from slot machines and hotel check-in systems to customer data and internal business platforms, creating a wide and connected attack surface. This interconnectedness meant that a successful breach of the infrastructure controlling access to all these systems would cascade across the entire operation (Schrader, 2025; Sudbeck, 2024). That is exactly what Scattered Spider exploited.

MGM also held a vast amount of customer data, including names, contact information, date of births, driver's license numbers, Social Security numbers, passport numbers, and military

identification numbers (Culafi, 2023). This made data exfiltration a tool for extortion. This raises an ethical tension between business convenience and customer privacy, as storing highly sensitive data in centralized systems increases the risk of severe harm if breached. Organizations should consider whether the value of collecting this data outweighs the potential consequences of its exposure.

Step By Step Attack

The MGM attack is a case study in identity-centered social engineering. No malware was deployed to gain initial access. No technical vulnerability was exploited. The entire operation was based on the manipulation of human trust.

Reconnaissance

Before the attack, Scattered Spider members conducted OSINT reconnaissance using LinkedIn. They identified a specific MGM employee, including their name and job title. They then built a profile with details to impersonate them (Schrader, 2025; Sudbeck, 2024). This phase also included researching MGM's SSPR workflows to understand what account recovery options were available and whether they could be exploited.

Help Desk Call

The attackers called MGM's IT help desk and impersonated the employee. Using personal details sourced from LinkedIn, they convinced the help desk agent to reset the employee's password and MFA configuration (Culafi, 2023; Sudbeck, 2024). The call lasted less than ten minutes. Once finished, Scattered Spider had access to MGM's Okta identity environment.

Cloud Identity Exploitation

With Okta credentials and administrative privileges, the attackers expanded their access. Using Okta admin control, they gained administrator access to MGM's Microsoft Azure tenant

and used Azure AD PowerShell to list accounts and identify high-value targets. They then targeted privileged service accounts, including the Azure Active Directory Sync account, and reset their credentials. Next, they created new administrative accounts disguised as service accounts by following MGM's existing naming conventions. Conditional Access Policies enforcing MFA and IP restrictions were deleted, allowing unrestricted access. Finally, temporary Access Passes were registered on multiple accounts, providing MFA-bypassing access tokens that remained valid even after password resets (Obsidian, 2025; Schrader, 2025).

Lateral Movement

Okta's SSO capabilities which were designed to make employee access easy became the attacker's main way through MGM's environment (Foulger, 2025; Obsidian, 2025). From the compromised cloud identity, attackers pivoted into the corporate VPN and internal network. Internal documentation hosted on SharePoint was accessed, providing a detailed map of MGM's IT infrastructure to guide exploitation.

Ransomware

With administrative access to MGM's environment established, Scattered Spider brought in their partner ALPHV. ALPHV deployed ransomware targeting MGM's VMware ESXi hypervisors. These servers hosted thousands of virtual machines powering MGM's guest-facing and operational systems. Approximately one hundred ESXi hypervisors were encrypted, taking the virtual machines offline. ALPHV also claims to have exfiltrated approximately six terabytes of customer data, which they threatened to release publicly if MGM did not pay the ransom (Baccio, 2024; Schrader, 2025).

Attack Timeline Table

The table below shows a day-by-day timeline of the MGM cyberattack and how the incident developed from the initial breach through to full recovery.

Date	Event
Sep 7, 2023	Scattered Spider breaches Caesars Entertainment using a third-party IT vendor. This was four days prior to the MGM attack.
Sep 8, 2023	Attackers breached MGM's network following the help desk social engineering call.
Sep 9, 2023	MGM security teams detect unusual activity and traffic patterns on systems.
Sep 10, 2023	MGM begins experiencing operational outages. ALPHV ransomware encrypts ESXi hypervisors.
Sep 11, 2023	MGM discloses the incident on social media. Law enforcement engaged and third-party cybersecurity experts were brought in. Certain systems were shut down to contain the breach.
Sep 12-13	Customers report cascading disruptions across all MGM properties. Slot machines offline. Digital room keys did not work. Reservation systems down.
Sep 14, 2023	ALPHV/Scattered Spider claims responsibility and announces theft of 6 TB of customer data. Ransom negotiation begins.
Sep 20, 2023	MGM confirms full restoration of all systems. Total outage duration was approximately ten days.

Analysis

Impact

Operational Impact

The impact of the attack was immediate and highly disruptive for MGM. Across its U.S. properties, slot machines and gaming systems went offline, showing error messages on casino floors. Digital room keys stopped working, forcing staff to manually issue physical keys to thousands of guests. Online reservation and booking systems were taken down, and the MGM mobile app was not accessible. Restaurant reservation systems were also disrupted across properties, and corporate email systems were affected, limiting communication (Brown & Brown, 2024; Schrader, 2025).

Financial Impact

MGM's decision not to pay the ransom aligned with guidance from cybersecurity experts, government agencies, and law enforcement. All warn that payment can encourage further attacks

without ensuring data recovery or preventing data disclosure. In contrast, Caesars Entertainment paid approximately \$15 million to the same group, showing that payment does not necessarily improve security outcomes. MGM reported significant losses in Q3 2023, including \$84 million in lost revenue, \$10 million in consulting and legal fees, \$40 million in IT infrastructure upgrades, and additional undisclosed costs related to customer remediation and litigation. This totals roughly \$100 million for the quarter (Brown & Brown, 2024; Culafi, 2023; Schrader, 2025).

This also reflects an ethical dilemma that paying the ransom may protect customer data in the short term, but it motivates future criminal activity. Refusing to pay aligns with broader societal interests but may increase immediate harm to affected individuals.

Data Compromise

The personal data of millions of MGM customers was exfiltrated during the attack, affecting individuals who had made transactions with MGM before March 2019. The compromised data included full names and contact information, date of births and driver's license numbers, Social Security and passport numbers, reservation records and loyalty program details, as well as potential exposure of employee data. (Schrader, 2025; Sudbeck, 2024).

Legal Impact

The attack triggered immediate negative media coverage and social media backlash. Multiple class-action lawsuits were filed against MGM, stating that the company failed to implement cybersecurity measures and did not act on prior warnings from Okta regarding security risks.

Regulatory consequences followed, including an investigation by the Federal Trade Commission, which MGM contested in court, as well as reviews from multiple state regulators,

including the Nevada Gaming Control Board. MGM was also required to make disclosures to the U.S. Securities and Exchange Commission in compliance with company reporting obligations (Brown & Brown, 2024; Culafi, 2023).

Defensive Measures and Response

While the breach involved a help desk interaction, placing blame solely to an individual overlooks the larger failures. Ethically, responsibility lies in the design of controls rather than human error. An analysis of the MGM attack reveals multiple layers of failure in the human and procedural layer that supported them.

What MGM Didn't Do Well

Insufficient Help Desk Verification

The most critical failure was the absence of verifiable identity proof before a help desk agent reset credentials or modified authentication factors (Culafi, 2023; Sudbeck, 2024). MGM's help desk relied on information that an attacker could obtain in minutes from a public platform. There was no requirement for proof of identity, no verification, and no additional approval step for resetting MFA on an account.

Circumvent MFA

MGM had deployed MFA through Okta. Since a phone call to the help desk was sufficient to replace an MFA device, the control was ineffective against social engineering (MITRE, n.d.; Obsidian, 2025).

Ignored Prior Warnings

Lawsuits filed after the breach claimed that Okta had issued security alerts to MGM regarding risks, and that these warnings were not acted upon with urgency (Culafi, 2023). Threat intelligence and vendor security advisories must be implemented. This raises questions of corporate responsibility, as failing to act on known security warnings may represent not just

technical oversight but an ethical failure. Organizations have a duty to protect customer data when credible risks are identified.

SSO Lateral Movement Not Constrained

The SSO architecture that allowed attackers to move from cloud identity into the full network reflects a broad SSO scope (Foulger, 2025; Obsidian, 2025). A single compromised identity should not grant access to every system in the network. The lack of segmentation between SSO-enabled applications, and the cloud and on-premises systems, made the impact of the initial compromise worse.

Hypervisor Single Point of Failure

The targeting of VMware ESXi hypervisors and encrypting roughly one hundred of them took thousands of virtual machines offline, reflects a virtualization architecture without proper segmentation or backup and recovery mechanisms for critical systems (Baccio, 2024; CrowdStrike, 2026).

What MGM Did Well

Despite the scale of the breach, MGM's response demonstrated several strong characteristics. First, they acted quickly to contain the incident, making the decision to shut down critical systems. This was a defensively strong move. MGM also immediately engaged third parties, bringing in leading cybersecurity incident response firms and law enforcement rather than attempting to manage the crisis internally.

They maintained a degree of transparency through public disclosures on social media and by meeting SEC filing obligations, which helped maintain credibility with customers and regulators. MGM also provided comprehensive customer remediation, including a dedicated breach information portal, free credit monitoring and identity theft protection for affected

customers, and a dedicated call center to handle any questions (Brown & Brown, 2024; Schrader, 2025).

MGM declined to pay the ransom, which was consistent with best-practice guidance, avoiding funding the ransomware ecosystem and reducing the risk of becoming a repeat target (Culafi, 2023). Finally, MGM's commitment of up to \$40 million in IT security improvements shows the breach was treated as motivation for meaningful change.

Recommendations

Based on the MGM attack, the pattern of Scattered Spider campaigns, and cybersecurity best practice, the following recommendations represent a strong defensive posture against this type of social engineering threat.

Harden Help Desk Authentication

The help desk is one of the most critical control surfaces to secure. Organizations should implement multi-step identity verification before any agent resets credentials or changes authentication factors. Key measures include requiring manager or supervisor approval for MFA device replacement or credential resets, using video verification for high-risk requests, and applying time-delayed resets for administrative accounts with notification sent to the legitimate user through a different channel. Phone-based verification should never be the main method for resetting MFA, especially for privileged accounts. Certain high-risk accounts should be excluded from help desk resets entirely, requiring stronger verification methods (CrowdStrike, 2026; MITRE, n.d.).

Phishing Resistant MFA

Traditional push-based MFA and SMS-based OTP codes are vulnerable to both social engineering and interception. Organizations should move all privileged and administrative

accounts to FIDO2 or WebAuthn hardware security keys. These are physical devices such as YubiKeys that bind authentication to the correct domain (MITRE, n.d.). These methods can't be phished, socially engineered, or SIM-swapped. For standard employee accounts, passkey-based authentication provides a phishing-resistant alternative that does not require hardware tokens.

Zero Trust Architecture

Zero Trust is a design where no user or device is trusted by default, regardless of prior authentication. Key implementation elements include just-in-time deployment of administrative accounts, where temporary accounts with only the minimum required permissions are created for specific tasks and removed afterward. It also includes continuous verification of session context through ongoing checks of device health, location, and behavioral patterns throughout the session rather than only at login. Another core principle is enforcement of least-privilege access across all systems and applications, so users only have the access required for their role. Finally, organizations should use Privileged Access Workstations, which are hardened, dedicated devices used for administrative tasks to prevent privileged credentials from being exposed to general-purpose machines (MITRE, n.d.).

Protecting Cloud Identity Infrastructure

Given that cloud identity providers such as Okta and Microsoft Entra ID are primary targets for Scattered Spider, hardening these platforms is critical. Organizations should require phishing-resistant MFA for all cloud identity administrator accounts without exception. They should also implement and maintain Conditional Access Policies by blocking access from high-risk IP ranges, requiring managed devices for administrative actions, and enforcing strong MFA requirements for information registration. In addition, real-time alerting should be enabled for any changes to administrative role assignments, Conditional Access Policies, MFA device

registrations, and SSPR phone number changes. SSPR should also be restricted so that phone number changes require additional verification, since replacing a recovery number with a VoIP number should trigger a security review rather than an automatic reset. Finally, vendor security advisories must be acted on, with Okta security notifications and alerts treated as high-priority signals requiring immediate response (Foulger, 2025; Obsidian, 2025).

Constrain Lateral Movement

The speed of lateral movement in Scattered Spider attacks reflects an architecture without proper segmentation. Mitigations include limiting SSO scope so that a single compromised cloud identity can't cascade access to every system in the environment, and segmenting high-sensitivity systems, HR systems, and critical infrastructure from general SSO access.

Organizations should also implement network segmentation to restrict traffic between systems, preventing a compromised node from communicating with critical infrastructure, and segregate cloud and on-premises environments to ensure that a cloud identity compromise does not grant access to systems and hypervisors. Additionally, hypervisor environments such as VMware ESXi and other virtualization infrastructure should be protected separately by requiring dedicated credentials and not allowing access through SSO (Baccio, 2024; CrowdStrike, 2026).

Conduct Social Engineering Simulations

Technical defenses can't compensate for untested human processes, so organizations should expand their security testing programs accordingly. This includes conducting phishing simulation exercises where red team operators attempt to socially engineer the help desk using techniques like Scattered Spider, with results used to identify gaps and improve training. Organizations should also carry out regular OSINT audits to evaluate what information about employees is publicly available on platforms such as LinkedIn, since limiting publicly exposed information

makes impersonation more difficult (Avanzato, 2025; CrowdStrike, 2026). In addition, tabletop exercises should be run to rehearse responses to identity-based attacks, focusing not only on ransomware recovery but on scenarios where an attacker has already gained administrative access to cloud identity infrastructure. However, simulated attacks introduce ethical concerns, as intentionally deceiving employees can impact trust within the organization. These exercises must be carefully framed to support learning rather than create fear or blame.

Behavioral Detection

Standard perimeter and endpoint detection tools are often ineffective against Scattered Spider because attackers use legitimate credentials and operate through trusted channels, so detection must instead focus on identity-layer anomalies (Foulger, 2025). Key indicators include multiple failed or unusual SSPR attempts from unknown IP addresses, changes to account recovery phone numbers to VoIP providers such as Google Voice, and new MFA device registrations with off-hours logins or access from unusual locations. Other red flags include administrative role assignments to accounts that have not held privileges, as well as any deletion or modification of Conditional Access Policies, which should trigger immediate alerts. Organizations should also monitor logins from satellite IP addresses, commercial VPN services such as Mullvad and ExpressVPN, or IP ranges linked to known malicious infrastructure, along with bulk account disabling actions, which can indicate an attempt to disrupt incident response.

Manage Third Party and Supply Chain Risks

Caesars Entertainment was breached through a third-party IT vendor, highlighting that this attack vector is not an incident. Scattered Spider targets supply chain relationships as softer entry points into high-value organizations. Key requirements include applying the same authentication and verification standards to all vendors with privileged access to internal systems

as to internal staff, ensuring that help desk controls are no weaker at a third-party provider than they are internally. Organizations should also regularly audit third-party access scopes and remove unnecessary permissions so that vendors only have access to the systems required for their role, include social engineering resilience as part of vendor security assessments and contractual obligations, and require vendors to report any social engineering attempts targeting their staff that relate to the organization's systems (Culafi, 2023).

Build Incident Response Capability

MGM's response demonstrated the value of pre-existing incident response planning. Organizations should invest in a documented and regularly rehearsed incident response plan that specifically addresses identity-based attacks. They should also establish relationships in advance with cybersecurity incident response firms so that their involvement during a crisis happens quicker and define containment actions that can be authorized and executed rapidly without lengthy approval chains. In addition, organizations should conduct regular tabletop and full-scale simulation exercises that incorporate not only technical response but also public communications, regulatory notification, and coordination with law enforcement (Brown & Brown, 2024; Schrader, 2025).

Conclusion

Scattered Spider represents an evolution in the cybercriminal threat landscape (Avanzato, 2025; CrowdStrike, 2026). They are not state-sponsored hackers with unlimited resources, or malware developers. They are young people with smartphones and a talent for conversation, and they have caused hundreds of millions of dollars in damage to some of the world's most security-conscious organizations.

The MGM Resorts attack is the ultimate case study in this threat. A single phone call gave Scattered Spider administrative access to one of the largest hospitality networks (Culafi, 2023; Sudbeck, 2024). Following this was ten days of operational chaos, \$100 million in damages, the exposure of customers' personal data, and years of litigation and investigations.

The attack's central lesson is unavoidable. Technical security controls are only as strong as the human processes that control them (MITRE, n.d.). MFA protects an account only until a help desk agent is convinced to reset it. Network segmentation only constrains an attacker who is not authenticated as an administrator. Conditional Access Policies only function until an attacker with admin privileges deletes them.

Scattered Spider continues to evolve. The group's decentralized structure and continued recruitment of new members have ensured that law enforcement actions have not disrupted their operations.

Organizations that understand this threat actor's playbook, harden their human-layer controls with the same discipline they apply to their technical architecture, and build a tested incident response capability will be better positioned to resist the next Scattered Spider campaign.

References

- Australian Cyber Security Centre. (2025). *Scattered Spider* | *Cyber.gov.au*. Cyber.gov.au.
<https://www.cyber.gov.au/about-us/view-all-content/alerts-and-advisories/scattered-spider>
- Avanzato, J. (2025, May 30). *Scattered Spider: What You Need to Know*. Varonis.com; Varonis.
<https://www.varonis.com/blog/scattered-spider>
- Baccio, M. (2024). *Scattered Spider: What You Need to Know* | *Splunk*. Splunk; Splunk.
https://www.splunk.com/en_us/blog/learn/scattered-spider.html
- Bitsight TRACE. (2025). *Scattered Spider Ransomware Group: Activity, TTPs, & More*. Bitsight.
<https://www.bitsight.com/blog/who-is-scattered-spider-ransomware-group>
- Brown & Brown. (2024). *A Look Back at the MGM and Caesars Incident*. Brown & Brown.
<https://www.bbrown.com/us/insight/a-look-back-at-the-mgm-and-caesars-incident/>
- Cartwright, E., Hernandez Castro, J., & Cartwright, A. (2019). To pay or not: game theoretic models of ransomware. *Journal of Cybersecurity*, 5(1).
<https://doi.org/10.1093/cybsec/tyz009>
- CISA. (2022). *CISA | DEFEND TODAY, SECURE TOMORROW Implementing Phishing-Resistant MFA*. <https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf>
- CrowdStrike. (2026). *Scattered Spider Adversary Profile* | *CrowdStrike*. Crowdstrike.com.
<https://www.crowdstrike.com/en-us/adversaries/scattered-spider/>
- Culafi, A. (2023, September 20). *Okta: Caesars, MGM hacked in social engineering campaign* | *TechTarget*. Security. <https://www.techtarget.com/searchsecurity/news/366552775/Okta-Caesars-MGM-hacked-in-social-engineering-campaign>

Culley, A. (2025, September 22). *Scattered Spider: What You Need to Know* | SafeBreach.

SafeBreach. <https://www.safebreach.com/blog/scattered-spider/>

Cyber Safety Review Board. (2022). *CSRB REVIEW: ATTACKS ASSOCIATED WITH LAPSUS\$ AND RELATED THREAT GROUPS—KEY FINDINGS AND RECOMMENDATIONS*.

[https://www.cisa.gov/sites/default/files/2023-](https://www.cisa.gov/sites/default/files/2023-08/Review%20Of%20The%20Attacks%20Associated%20with%20Lapsus%20And%20Related%20Threat%20Groups%20Executive%20Summary_508c.pdf)

[08/Review%20Of%20The%20Attacks%20Associated%20with%20Lapsus%20And%20Related%20Threat%20Groups%20Executive%20Summary_508c.pdf](https://www.cisa.gov/sites/default/files/2023-08/Review%20Of%20The%20Attacks%20Associated%20with%20Lapsus%20And%20Related%20Threat%20Groups%20Executive%20Summary_508c.pdf)

DOJ, & CISA. (2023). *Joint Cybersecurity Advisory - Scattered Spider*.

https://www.cisa.gov/sites/default/files/2023-11/aa23-320a_scattered_spider_0.pdf

Ferreira, A., Coventry, L., & Lenzini, G. (2015). Principles of Persuasion in Social Engineering and Their Use in Phishing. *Lecture Notes in Computer Science*, 9190, 36–47.

https://doi.org/10.1007/978-3-319-20376-8_4

Foulger, E. (2025, July 24). *Top Defensive Tactics for CISOs Against Scattered Spider*.

Darktrace.com; Darktrace. <https://www.darktrace.com/blog/untangling-the-web-darktraces-investigation-of-scattered-spiders-evolving-tactics>

Henriques, T. (2025). *Scattered Spider: Hacker Collective Ensnaring Industry-Specific Targets*.

Coalitioninc.com. <https://www.coalitioninc.com/blog/security-labs/scattered-spider-hacker-collective-ensnaring-industry-specific-targets>

Huntress. (n.d.). *Scattered Spider Threat Actor Profile: TTPs, IOCs & Attacks* | Huntress.

Huntress. <https://www.huntress.com/threat-library/threat-actors/scattered-spider>

Jones, K. S., Armstrong, M. E., Tornblad, M. K., & Siami Namin, A. (2020). How social engineers use persuasion principles during phishing attacks. *Information & Computer Security*, 29(2), 314–331. <https://doi.org/10.1108/ics-07-2020-0113>

- Lazerowitz, R. (2025). *Mirage Security - Scattered Spider Attacks: Timeline, Tactics, and Defense Tips*. Miragesecurity.ai. <https://www.miragesecurity.ai/blog/scattered-spider-a-retrospective>
- MITRE. (n.d.). *Scattered Spider, Roasted Oktapus, Group G1015 | MITRE ATT&CK®*. Attack.mitre.org. <https://attack.mitre.org/groups/G1015/>
- Obsidian. (2025). *Behind the Breach: Scattered Spider SaaS Attack Analysis & MITRE ATT&CK Mapping*. Obsidiansecurity.com. <https://www.obsidiansecurity.com/blog/scattered-spider-saas-attack-analysis>
- Phipps, A., & Nurse, J. R. C. (2025). Inside Ransomware Groups: An Analysis of their Origins, Structures, and Dynamics. *Computers & Security*, 104705. <https://doi.org/10.1016/j.cose.2025.104705>
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020, August 11). *Zero Trust Architecture*. Csrc.nist.gov. <https://csrc.nist.gov/pubs/sp/800/207/final>
- Salahdine, F., & Kaabouch, N. (2019). Social Engineering Attacks: A Survey. *Future Internet*, 11(4), 89. <https://www.mdpi.com/1999-5903/11/4/89>
- Scattered Spider*. (2023, September 26). Wikipedia. https://en.wikipedia.org/wiki/Scattered_Spider
- Schrader, D. (2025, February 14). *An Overview of the MGM Cyber Attack*. Netwrix.com. <https://netwrix.com/en/resources/blog/mgm-cyber-attack/>
- Sudbeck, R. (2024, August 12). *What everyone got wrong about the MGM hack | IPassword*. 1password.com. <https://1password.com/blog/mgm-hack>
- Triantafyllopoulos, A., Spiesberger, A. A., Tsangko, I., Jing, X., Distler, V., Dietz, F., Alt, F., & Schuller, B. W. (2025). Vishing: Detecting social engineering in spoken communication

— A first survey & urgent roadmap to address an emerging societal challenge. *Computer Speech & Language*, 94, 101802. <https://doi.org/10.1016/j.csl.2025.101802>